COBIT

Governance and Management of Enterprise IT

Joao Luiz D'Andrea

Table of contents

1 Overview **2**
- 1.1 What is COBIT . . . 2
- 1.2 Purpose . . . 2
- 1.3 When to Use It . . . 3
- 1.4 Target Audience . . . 3
- 1.5 COBIT Governance System . . . 4

2 History and Evolution **4**

3 Core Principles **5**

4 Governance Structure **6**
- 4.1 Governance vs Management . . . 6
- 4.2 Governance Domain . . . 6
- 4.3 Management Domains . . . 7
- 4.4 Governance Components . . . 7
- 4.5 Design Factors . . . 8

5 Processes **8**
- 5.1 EDM — Evaluate, Direct and Monitor . . . 8
- 5.2 APO — Align, Plan and Organise . . . 8
- 5.3 BAI — Build, Acquire and Implement . . . 9
- 5.4 DSS — Deliver, Service and Support . . . 9
- 5.5 MEA — Monitor, Evaluate and Assess . . . 10
- 5.6 How to Read the Process Model . . . 10

6 Documentation and Artefacts **10**
- 6.1 Typical COBIT Artefact Families . . . 11
- 6.2 COBIT Documentation RACI Matrix . . . 11

6.3 Artefacts by COBIT Domain 16

7 Integration with Other Frameworks **16**

8 Implementation Approach **17**
8.1 Common Implementation Tips 18

9 KPIs and Metrics **19**
9.1 Metric Design Guidance 19

10 Benefits **20**

11 Limitations **20**

12 Example Use Case **21**
12.1 Scenario: Mid-Sized Financial Services Organisation 21
12.1.1 How COBIT Helps 21
12.1.2 Key Artefacts Produced 21
12.1.3 Expected Outcomes 21

13 References **22**

1 Overview

1.1 What is COBIT

COBIT is a framework from ISACA for the governance and management of enterprise information and technology. It helps organisations ensure that information and technology support business goals, deliver value, optimise risk, and use resources responsibly.

COBIT is not just an IT operations model. It is an enterprise governance framework that connects board priorities, executive decision-making, control requirements, architecture, service delivery, security, assurance, and performance measurement into one coherent system.

1.2 Purpose

The purpose of COBIT is to help enterprises:

- create value from information and technology;
- balance benefits realisation, risk optimisation, and resource optimisation;
- align technology decisions with stakeholder needs and enterprise strategy;
- establish clear governance accountabilities;
- define management objectives, controls, and performance measures; and

- provide a common language between the board, executives, auditors, risk, architecture, security, and operational teams.

1.3 When to Use It

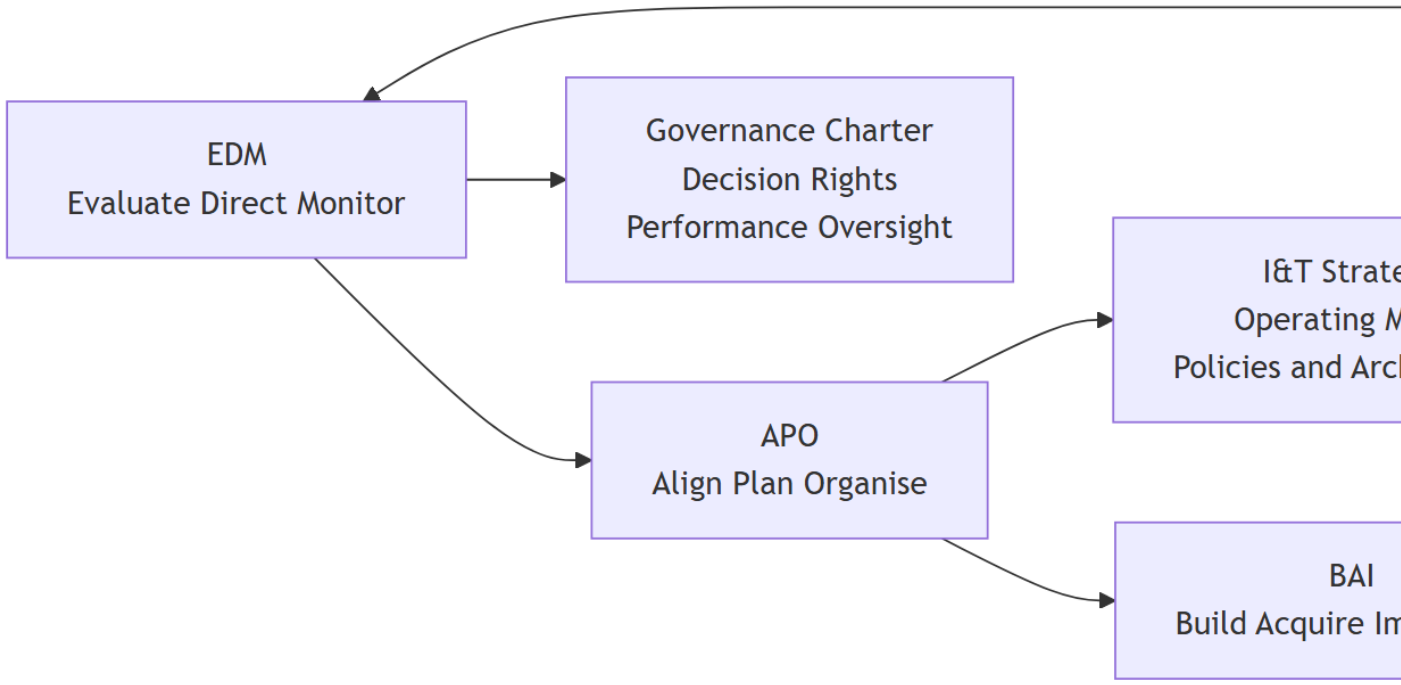
COBIT is especially useful when an organisation needs a structured governance model across multiple technology and business functions. Typical situations include:

- enterprise-wide IT governance transformation;
- strengthening board oversight of digital and technology investment;
- integrating risk, compliance, security, architecture, and service management;
- improving auditability and control maturity;
- rationalising overlapping frameworks and standards;
- creating a governance layer above delivery frameworks such as PRINCE2, MSP, Agile, DevOps, or ITIL; and
- supporting regulated or high-dependability environments.

1.4 Target Audience

- Board and governing body
- CIO
- CISO
- Chief Digital / Transformation leaders
- IT Governance Board
- Enterprise Architects
- PMO / Transformation Office
- Risk, compliance, and internal audit teams
- Service management and operations leaders

1.5 COBIT Governance System



COBIT separates **governance** from **management**. Governance is exercised by those who evaluate stakeholder needs, direct priorities, and monitor outcomes. Management plans, builds, runs, and monitors activities in line with that policy and direction.

---

2 History and Evolution

Version	Year	Key Changes
COBIT 1	1996	Initial control objective framework focused on audit and control of IT
COBIT 2	1998	Expanded control guidance and broader management use
COBIT 3	2000	Greater management orientation and maturity thinking
COBIT 4.0	2005	Stronger governance emphasis and process structure
COBIT 4.1	2007	Refined process model, controls, goals, and maturity guidance
COBIT 5	2012	Integrated governance and management of enterprise IT; five principles and seven enablers
COBIT 2019	2018/2019	Updated core model, design factors, focus areas, performance management, and tailoring guidance

COBIT has evolved from an audit and control reference into a broader governance system for enterprise information and technology. The most significant step was COBIT 5, which repositioned the framework around value creation and the governance of enterprise IT. COBIT 2019 then improved tailoring and practical implementation through design factors and focus areas.

---

3 Core Principles

COBIT 2019 is commonly explained through governance system principles such as:

1. **Provide stakeholder value**
   Governance exists to create value by balancing benefits, risk, and resource use.
2. **Holistic approach**
   Effective governance depends on multiple components working together, including processes, structures, policies, culture, information, skills, and services.

3. **Dynamic governance system**
   Governance is not static. It must respond to strategy, risk, regulation, technology change, sourcing models, and enterprise context.
4. **Governance distinct from management**
   Governance decides, directs, and monitors. Management plans, builds, runs, and monitors operations and change.
5. **Tailored to enterprise needs**
   COBIT is designed to be adapted using design factors such as enterprise strategy, risk profile, compliance requirements, threat landscape, implementation methods, and enterprise size.
6. **End-to-end governance system**
   COBIT covers the whole enterprise, not only the IT department. It includes all information and technology processing needed to support business goals.

These principles are important because they prevent COBIT from being treated as only a control checklist. In practice, COBIT works best when it is used as a design framework for how the organisation governs digital, information, services, security, architecture, investment, and change.

---

4 Governance Structure

4.1 Governance vs Management

COBIT makes a deliberate distinction between governance and management:

- **Governance** ensures stakeholder needs, conditions, and options are evaluated to determine balanced, agreed enterprise objectives; direction is set through prioritisation and decision-making; and performance and compliance are monitored.
- **Management** plans, builds, runs, and monitors activities to achieve the direction set by the governing body.

This distinction is valuable because many organisations mix strategic oversight with operational delivery. COBIT helps clarify which decisions belong to the board or executive governing body and which belong to management functions.

4.2 Governance Domain

Domain	Description
EDM	Evaluate, Direct and Monitor. Focuses on governance system design, benefits delivery, risk optimisation, resource optimisation, and stakeholder transparency.

4.3 Management Domains

Domain	Description
APO	Align, Plan and Organise. Covers strategy, architecture, innovation, budgeting, HR, relationships, suppliers, quality, risk, security, and data.
BAI	Build, Acquire and Implement. Covers programmes, requirements, solutions, change enablement, release, availability, knowledge, assets, and projects.
DSS	Deliver, Service and Support. Covers operations, service requests, incidents, problems, continuity, security services, and business process controls.
MEA	Monitor, Evaluate and Assess. Covers performance monitoring, internal control, compliance, and assurance.

4.4 Governance Components

A COBIT governance system is not made only of processes. It includes several interdependent components:

- processes;
- organisational structures;
- principles, policies, and procedures;
- information flows and items;
- culture, ethics, and behaviour;
- people, skills, and competencies; and
- services, infrastructure, and applications.

This is one of COBIT's strengths: it connects formal process design with the human, structural, and informational conditions needed for governance to work.

4.5 Design Factors

COBIT 2019 introduces design factors to tailor the governance system. Typical examples include:

- enterprise strategy;
- enterprise goals;
- risk profile;
- I&T-related issues;
- threat landscape;
- compliance requirements;
- role of IT within the enterprise;
- sourcing model;
- implementation methods;
- technology adoption strategy; and
- enterprise size.

These design factors help avoid implementing every objective with equal depth. Instead, the organisation can decide where to focus more governance effort.

---

5 Processes

COBIT 2019 defines 40 governance and management objectives grouped into five domains.

5.1 EDM — Evaluate, Direct and Monitor

Process	Name
EDM01	Ensured Governance Framework Setting and Maintenance
EDM02	Ensured Benefits Delivery
EDM03	Ensured Risk Optimisation
EDM04	Ensured Resource Optimisation
EDM05	Ensured Stakeholder Engagement

5.2 APO — Align, Plan and Organise

Process	Name
APO01	Managed I&T Management Framework
APO02	Managed Strategy
APO03	Managed Enterprise Architecture
APO04	Managed Innovation
APO05	Managed Portfolio
APO06	Managed Budget and Costs
APO07	Managed Human Resources
APO08	Managed Relationships
APO09	Managed Service Agreements
APO10	Managed Vendors
APO11	Managed Quality
APO12	Managed Risk
APO13	Managed Security
APO14	Managed Data

5.3 BAI — Build, Acquire and Implement

Process	Name
BAI01	Managed Programs
BAI02	Managed Requirements Definition
BAI03	Managed Solutions Identification and Build
BAI04	Managed Availability and Capacity
BAI05	Managed Organisational Change
BAI06	Managed IT Changes
BAI07	Managed IT Change Acceptance and Transitioning
BAI08	Managed Knowledge
BAI09	Managed Assets
BAI10	Managed Configuration
BAI11	Managed Projects

5.4 DSS — Deliver, Service and Support

Process	Name
DSS01	Managed Operations
DSS02	Managed Service Requests and Incidents
DSS03	Managed Problems
DSS04	Managed Continuity

Process	Name
DSS05	Managed Security Services
DSS06	Managed Business Process Controls

5.5 MEA — Monitor, Evaluate and Assess

Process	Name
MEA01	Managed Performance and Conformance Monitoring
MEA02	Managed System of Internal Control
MEA03	Managed Compliance With External Requirements
MEA04	Managed Assurance

5.6 How to Read the Process Model

The COBIT process model should be used as a governance map rather than a rigid sequence. The objectives describe what must be governed or managed; they do not force a single operating design. For example:

- APO02 and APO05 connect strategy with portfolio choices;
- APO03 connects architecture to standards and future-state design;
- BAI01 and BAI11 help structure delivery change through programmes and projects;
- DSS02, DSS03, and DSS04 support reliable service operations and resilience;
- MEA02, MEA03, and MEA04 provide the assurance layer needed for control, compliance, and audit.

---

6 Documentation and Artefacts

This section defines the key documents produced within the framework and the roles responsible for creating, approving, and maintaining them.

6.1 Typical COBIT Artefact Families

COBIT does not prescribe one mandatory document pack for every organisation. Instead, artefacts are produced as evidence that governance decisions, management practices, controls, and oversight activities are functioning. A practical COBIT implementation usually generates artefacts across the following families:

- governance and decision-rights documents;
- strategy, architecture, and operating model artefacts;
- portfolio, programme, project, and change artefacts;
- risk, control, security, and compliance artefacts;
- service management and operational artefacts; and
- performance, assurance, and audit artefacts.

6.2 COBIT Documentation RACI Matrix

Legend: R = Responsible, A = Accountable, C = Consulted, I = Informed

Document / Artefact	Board / Governing Body	CIO / Head of IT	Enterprise Architect	PMO / Transformation Office	Risk & Compliance	Service Owner / Ops Manager	Internal Audit
Governance System Charter	A	R	C	I	C	I	I
Decision Rights Matrix	A	R	C	I	C	I	I
I&T Strategy	I	A	R	C	C	I	I
Enterprise Architecture Principles	I	A	R	C	I	C	I

Document / Artefact	Board / Governing Body	CIO / Head of IT	Enterprise Architect	PMO / Transformation Office	Risk & Compliance	Service Owner / Ops Manager	Internal Audit
Governance Policy Set	A	R	C	I	C	I	C
IT Operating Model	I	A	C	R	C	C	I
Portfolio Prioritisation Criteria	C	A	C	R	C	I	I
Portfolio Roadmap	I	A	C	R	C	I	I
Business Case Standard	I	A	C	R	C	I	I
Benefits Realisation Plan	I	A	C	R	C	I	I
Risk Management Framework	C	A	I	I	R	I	C
IT Risk Register	I	A	I	I	R	C	C
Control Catalogue	I	A	C	I	R	C	C

Document / Artefact	Board / Governing Body	CIO / Head of IT	Enterprise Architect	PMO / Transformation Office	Risk & Compliance	Service Owner / Ops Manager	Internal Audit
Information Security Policy	I	A	C	I	R	C	C
Data Governance / Classification Standard	I	A	C	I	R	C	I
Change Management Policy	I	A	I	C	C	R	I
Change Record / Change Log	I	C	I	I	I	A/R	I
Service Catalogue	I	A	C	I	I	R	I
Service Level Agreement / OLA	I	A	I	I	I	R	I
Incident Management Procedure	I	A	I	I	C	R	I

Document / Artefact	Board / Governing Body	CIO / Head of IT	Enterprise Architect	PMO / Transformation Office	Risk & Compliance	Service Owner / Ops Manager	Internal Audit
Problem Record / Known Error Record	I	C	I	I	I	A/R	I
Availability / Capacity Plan	I	A	C	I	I	R	I
Supplier Management Policy	I	A	I	C	C	R	I
Supplier Performance Report	I	A	I	I	C	R	I
Project Governance Framework	I	A	C	R	C	I	I
Project / Programme Status Dashboard	I	A	I	R	C	I	I

Document / Artefact	Board / Governing Body	CIO / Head of IT	Enterprise Architect	PMO / Transformation Office	Risk & Compliance	Service Owner / Ops Manager	Internal Audit
Release / Deployment Plan	I	C	C	I	I	A/R	I
Business Continuity / DR Plan	I	A	C	I	R	C	C
Performance and KPI Dashboard	I	A	I	C	C	R	I
Compliance Assessment Report	I	A	I	I	R	I	C
Control Testing / Assurance Report	I	C	I	I	C	I	A/R
Audit Report	I	C	I	I	C	I	A/R
Management Action Plan	I	A	I	C	R	C	C
Lessons Learned Repository	I	A	I	R	C	C	I

6.3 Artefacts by COBIT Domain

Domain	Typical Artefacts
EDM	Governance charter, board dashboards, benefits oversight reports, risk appetite statements, decision rights matrix
APO	strategy, target operating model, architecture principles, portfolio criteria, policy set, budgets, vendor governance, risk and security frameworks
BAI	programme and project plans, business cases, requirements packs, change records, release plans, capacity plans, configuration baselines
DSS	service catalogue, SLAs/OLAs, run books, incident/problem records, continuity plans, security operations procedures
MEA	KPI dashboards, compliance reports, control testing packs, audit reports, management action trackers

---

7 Integration with Other Frameworks

COBIT often acts as the governance umbrella over more specialised delivery and operating frameworks.

Framework	Relationship with COBIT
ITIL	ITIL provides detailed service management practices. COBIT provides governance objectives, decision rights, control focus, and performance oversight for service management.
TOGAF	TOGAF provides architecture development methods and artefacts. COBIT provides governance for architecture, priorities, compliance, and enterprise alignment.

Framework	Relationship with COBIT
PRINCE2	PRINCE2 structures project management. COBIT provides enterprise governance, portfolio alignment, benefits oversight, controls, and assurance expectations.
MSP	MSP supports programme governance and change orchestration. COBIT helps ensure programme decisions align with enterprise objectives and risk appetite.
PMBOK / PMI practices	PMBOK gives delivery guidance and management practices. COBIT strengthens governance, controls, assurance, and alignment to enterprise value.
ISO/IEC 38500	ISO/IEC 38500 provides high-level corporate governance principles for IT. COBIT translates governance intent into an implementable model.
ISO 27001 / NIST CSF	These provide security and control guidance. COBIT helps integrate them into enterprise governance, accountability, monitoring, and assurance.
GDPR / DORA / NIS2	COBIT can support compliance by linking regulatory obligations to policies, controls, roles, metrics, and assurance mechanisms.

A practical rule is this: **COBIT governs, while other frameworks often specialise**. This makes COBIT useful as the integrating layer in complex organisations with many standards already in place.

---

8 Implementation Approach

A pragmatic COBIT implementation should be iterative and tailored. A typical approach is:

1. **Understand drivers and pain points**
   Identify why governance improvement is needed: regulatory pressure, weak prioritisation, poor benefits realisation, fragmented controls, audit findings, weak architecture discipline, or service instability.

2. **Assess the current state**
   Review current governance structures, decision forums, processes, artefacts, roles, metrics, and maturity. Map existing practices to COBIT objectives.

3. **Define governance scope and priorities**
   Use design factors to determine which objectives matter most. Not every domain requires the same implementation depth.

4. **Design the target governance system**
   Define structures, policies, decision rights, information flows, metrics, escalation paths, and assurance mechanisms.

5. **Select priority objectives and artefacts**
   Focus first on the objectives that solve the most critical enterprise issues, such as strategy, portfolio, risk, security, service reliability, or compliance.

6. **Implement roles, controls, and reporting**
   Create or update charters, policy sets, management forums, dashboards, architecture controls, and RACI structures.

7. **Embed into delivery and operations**
   Ensure COBIT is reflected in project governance, service management, vendor governance, data governance, and assurance activities.

8. **Measure, assure, and improve**
   Use KPIs, capability assessments, audits, and management reviews to refine the governance system over time.

8.1 Common Implementation Tips

- Start with the pain points, not the framework vocabulary.
- Use COBIT to unify what already exists instead of replacing every method.
- Keep governance forums clear and decision-oriented.
- Design concise artefacts that support decisions and evidence controls.
- Integrate governance metrics with portfolio, operational, security, and audit dashboards.
- Build strong ownership for APO02, APO05, APO12, APO13, DSS02, DSS04, and MEA02/03 in most enterprises.

---

9 KPIs and Metrics

COBIT encourages measurement across governance, management, performance, conformance, risk, and value. Example KPIs include:

KPI	Measurement
Benefits Realisation Rate	% of planned benefits achieved after implementation
Strategic Alignment Score	% of active initiatives explicitly linked to strategic objectives
Portfolio Delivery Confidence	% of portfolio rated green or amber-green for scope, cost, time, and benefits
Policy Compliance Rate	% of assessed units complying with mandatory governance policies
Audit Finding Closure Time	Average days to close agreed audit actions
Control Effectiveness	% of key controls operating effectively during testing
Service Availability	% uptime for critical services
Major Incident Frequency	Number of priority incidents per month or quarter
Mean Time to Resolve	Average resolution time for incidents by priority
Change Success Rate	% of changes implemented without rollback or major incident
Risk Exposure Trend	Change in aggregate inherent or residual risk over time
Vendor Performance Score	% of strategic suppliers meeting contractual and service targets
Architecture Compliance Rate	% of solutions reviewed that comply with target architecture standards
Data Quality Index	Composite score for completeness, accuracy, timeliness, and consistency
Training / Competency Coverage	% of critical governance roles with required skills and training

9.1 Metric Design Guidance

Good COBIT metrics should balance:

- **value**: are we delivering the intended outcomes?
- **risk**: are exposures within appetite?

- **resources**: are people, money, data, and services used effectively?
- **conformance**: are controls and obligations being met?
- **improvement**: are capability and governance maturity advancing?

---

10 Benefits

A well-implemented COBIT-based governance system can provide:

- clearer decision rights between board, executives, and management;
- stronger alignment between enterprise strategy and technology investment;
- improved benefits realisation from digital and change initiatives;
- better integration of risk, compliance, security, architecture, and service management;
- more consistent policy and control structures;
- better audit readiness and assurance evidence;
- stronger prioritisation of scarce resources; and
- a common governance language across business and technology stakeholders.

---

11 Limitations

COBIT is powerful, but it also has practical limitations:

- it can feel abstract if implemented without reference to real pain points;
- it requires interpretation and tailoring rather than mechanical adoption;
- it is not a detailed operating manual for every specialist practice;
- it can create documentation overhead if governance is over-engineered; and
- success depends heavily on leadership sponsorship and decision discipline.

In short, COBIT works best when used as a design and governance framework, not as a bureaucratic checklist.

---

12 Example Use Case

12.1 Scenario: Mid-Sized Financial Services Organisation

A regulated financial services organisation has grown through acquisitions. It has duplicated systems, inconsistent architecture decisions, unclear ownership of technology investment, increasing audit findings, weak visibility of risk, and recurring service incidents.

12.1.1 How COBIT Helps

- **EDM** establishes board-level oversight of benefits, risk, resources, and stakeholder transparency.
- **APO02** creates a single I&T strategy aligned to enterprise priorities.
- **APO03** defines architecture principles and review controls.
- **APO05** improves portfolio governance and prioritisation.
- **APO12** and **APO13** strengthen risk and security governance.
- **BAI01** and **BAI11** structure change through programme and project governance.
- **DSS02**, **DSS03**, and **DSS04** improve operational reliability, problem management, and continuity.
- **MEA02** and **MEA03** support control monitoring and regulatory compliance.

12.1.2 Key Artefacts Produced

- governance charter and decision rights matrix;
- integrated I&T strategy and target operating model;
- enterprise architecture principles and review board terms of reference;
- portfolio prioritisation model and benefits reporting pack;
- risk and control catalogue linked to regulatory requirements;
- service dashboards for incidents, changes, availability, and continuity;
- assurance plan and audit action tracker.

12.1.3 Expected Outcomes

Within 12 to 18 months, the organisation should expect better governance visibility, fewer duplicate initiatives, clearer accountability, improved audit closure rates, stronger change control, and more reliable critical services.

---

13 References

- ISACA. *COBIT 2019 Framework: Introduction and Methodology.*
- ISACA. *COBIT 2019 Framework: Governance and Management Objectives.*
- ISACA. *COBIT Design Guide: Designing an Information and Technology Governance Solution.*
- ISACA. *COBIT Implementation Guide: Implementing and Optimizing an Information and Technology Governance Solution.*
- ISO/IEC 38500. *Governance of IT for the organization.*
- Related integration references: ITIL, TOGAF, PRINCE2, MSP, ISO 27001, NIST CSF, and applicable regulatory frameworks.